

AI 에이전트를 위한 MCP와 보안 기술 동향

김현지*, 윤세영*, 서화정**

*한성대학교 (대학원생)

**한성대학교 (교수)

Security Technology Trends for AI Agents

Hyun-Ji Kim*, Se-young Yoon*, Hwa-Jeong Seo*

*Hansung University(Graduate student)

**Hansung University(Professor)

요약

AI agent는 기존의 LLM을 확장하여 외부 도구 호출을 통해 사전학습되지 않은 데이터에 대한 응답 및 작업을 수행할 수 있다. 이를 위해 모델 컨텍스트 프로토콜 (Model Context Protocol, MCP)를 사용한다. MCP는 AI 에이전트와 외부 서버와의 상호운용성은 높이지만 현재까지는 보안 기능을 필수로 요구하도록 표준화되어 있지 않다. 이로 인해 인증, 권한 부여, 무결성 등 여러 측면에서의 보안 문제가 발생할 수 있으므로, 대응 기술의 필요성이 높아지고 있다. 본 논문에서는 MCP를 활용하는 AI 에이전트의 보안 취약점과 이에 대응하기 위한 보안 기술 동향에 대해 살펴본다.

I. 서론

대규모 언어 모델 (Large Language Model, LLM)은 강력한 추론 기능을 제공하지만, 학습된 정보에 국한되므로 실시간 또는 도메인별 정보가 필요한 쿼리에 대한 응답 능력이 제한된다. 이러한 한계를 극복하기 위해 AI 에이전트 [1]는 데이터베이스, 웹 서비스, 엔터프라이즈 API와 같은 외부 정보에 접근함으로써 기능을 확장한다. 모델 컨텍스트 프로토콜 (Model Context Protocol, MCP) [2]은 에이전트와 호출 대상 도구와의 상호작용을 지원하는 개방형 표준으로 도입되어 기능 검색 및 호출을 위한 통합 프레임워크를 제공한다.

그러나 MCP는 외부 도구 및 데이터 소스를 연결하는 역할을 하므로 보안 문제가 발생하기 쉽다. 이와 더불어 인증, 권한 부여 및 세션 무결성을 위한 표준화된 메커니즘이 강제되지 않으므로 심각한 보안 허점을 안고 있다. 실제로, MCP를 활용한 이메일 서버 사용 과정에서 숨

은 참조 기능을 통해 외부로 메일 내용을 유출한 사례가 있다. 또한, MCP에 대한 공식 문서 [3]에서도 이러한 보안 위협에 대해 언급하고 있으며, 보안 모범 사례를 제시하는 등과 같이 프로토콜 레벨에서의 보안 패치를 권장하고 있는 상황이다.

II. 관련 배경

2.1 AI 에이전트

AI 에이전트는 입력을 수집하고, 목표 및 문맥 정보를 근거로 추론을 수행하며, 외부 환경에 대한 행위를 실행하는 자율적 소프트웨어 체계이다. LLM을 추론기로 사용하고, 작업 수행을 위해 도구 선택, 실행 및 검증을 수행한다. 단일 LLM과 달리, AI 에이전트는 데이터베이스 접근, API 호출, 코드 실행 등 외부 정보 및 기능의 통합을 통해 사전학습되지 않은 지식에 대한 작업이 가능하다. 이 과정에서 학습

되지 않은 다수의 외부 민감 데이터에도 접근하게 된다. 이처럼 작업 범위의 확장은 보안 요구 사항 등을 동반하며, 프로토콜 차원에서의 규약이 지원되어야 한다.

2.2 모델 컨텍스트 프로토콜 (MCP)

MCP는 에이전트와 외부 도구 사이의 기능 호출 및 사용, 컨텍스트 교환을 표준화한 개방형 규약이다. 도구가 제공하는 기능과 입출력 스키마를 기계가 읽을 수 있는 형태로 서술하고, 에이전트는 이를 근거로 호출을 구성하며 구조화된 응답을 수신한다. HTTP나 표준 입출력 등 다양한 환경에 이식 가능하고 상호운용성과 재현성이 높다.

2.3 MCP의 보안 취약점 및 요구 사항

MCP에서는 인증, 권한 부여, 세션 무결성, 정책 집행을 프로토콜 차원에서 강제하지 않는 설계가 기본이므로 사칭, 권한 남용, 세션 하이재킹, 재생 공격, 데이터 유출과 같은 위협이 존재한다. 도구 정의와 설명이 위·변조될 경우 에이전트가 악성 동작을 수행할 가능성이 있으며, 필요 이상의 권한, 입력 및 외부 컨텍스트를 매개로 정책을 우회하는 프롬프트 인젝션 또한 심각한 문제를 야기할 수 있다. 이러한 위협을 줄이려면, 최소권한과 단기 자격증명, 무결성 검증, 입출력 검사, 감사 가능 기록 같은 보안 프로토콜 및 구현 상의 보안 기능이 제공되어야 한다. 따라서 구현과 운영 전 주기에 걸친 검토와 감사 가능성 확보가 요구되며, 장기 보존 데이터 등을 고려하여 미래 환경에서의 암호 안전성까지 포함해 설계하는 것이 바람직하다.

III. AI 에이전트와 보안 기술 동향

본 장에서는 AI 에이전트의 보안 위협에 대한 대응 기술 연구를 살펴본다.

3.1 MCP 다층 보안 프레임워크

[4]에서는 MCP 취약점을 파악하고, 그에 대한 실행 가능한 보안 프레임워크를 제시한다. 해당 프레임워크는 취약점 파악을 위해 MCP 보안 위협을 총 7개의 계층 (데이터 운영, 에이전트 프레임워크, 배포 인프라, 보안 및 규정 등)으로 분류한다. 또한, MCP 프로토콜 사양과 확립된 위협 모델링 개념 (STRIDE [5]) 을 AI 에이전트 환경에 적용하여 보안 위협을 체계적으로 분류하고 식별할 수 있도록 한다.

제시된 보안 완화 전략은 NIST SP-800-53 [6], SP-800-207 [7], OWASP (Open Web Application Security Project) 가이드라인에 언급되는 보안 제어 및 제로트러스트 등을 기반으로 한다.

MCP 서버에 대한 완화책은 프로토콜 준수 검증을 통해 비정상 트래픽을 1차적으로 차단하고, 프롬프트 주입 및 데이터 유출을 탐지하는 규칙을 제공한다. 이와 더불어 TLS 1.2 이상 사용을 의무화하고, 우회 침투 방지, 속도 제어를 통한 DoS 및 무차별 대입 방지, 사용자 인증 및 권한 부여에 대한 기능도 제공한다.

클라이언트에 대한 대응책으로는 제로 트러스트 원칙하에 모든 상호작용을 요청 단위로 지속 검증한다. JIT (Just-in-Time) 접근 부여로 상시 권한을 제거하여 공격 표면을 최소화하고, 연속 검증 및 모니터링을 통한 세션 초과 신뢰 방지와 암호화를 통한 인증 및 무결성을 보장한다. 이외에도 로깅 기능 및 출력 필터링의 추가적인 보안 조치를 제공한다.

3.2 검증 가능한 정책 기반의 AI 에이전트

[8]에서는 최소 권한 원칙을 적용하여 자연어 정책을 해석하고 적용하는 방식을 제안한다. 이를 통해 감사 가능한 파이프라인을 구축하고, 검증 가능하고 더욱 안전하고 규제 가능한 AI 에이전트를 위한 기반을 마련한다.

사람 친화적으로 작성된 보안 규칙을 프롬프트로 컴파일하여 AI 에이전트가 따라야 할 실

행 규칙으로 변환하고, 경계(입출력)에서 실시간 보안 판정을 수행하도록 하는 기법이다.

이를 위해 사용자의 보안 의도를 추출하는 2단계 구문 분석을 수행한다. 1단계에서 LLM은 문서 계층 구조를 추론하고, 축약형 정책 명세를 추출한 후, 이를 VALINP (허용 가능한 입력), INVALIDP (허용 불가능한 입력, 예시: 도메인 외부 주제), VALOUT (정제), INVALIDOUT (환각, 정책 위반 또는 데이터 유출과 같은 금지된 출력)의 네 가지 범주로 분류한다. 2단계에서는 관련 출처 인용 사례를 기반으로 보장하여 맥락적 관계를 유지함으로써 신뢰도 높은 계층적 정책 트리를 생성한다.

이를 통해 입력 분류와 출력 감시를 일관된 기준으로 자동화하고, 정책 위반 시 응답을 차단, 경고, 교정하는 실행 경로를 제공한다.

3.3 양자 내성 MCP 보안 프로토콜

[9]에서는 기존 MCP가 가지는 인증, 인가 등에 대한 보안 위협과 함께 양자 내성 암호를 적용하여 양자 후 환경에서 유효한 보안 프로토콜을 제시한다. 특히, LLM이 입력되는 프롬프트에 대한 민감도와 맥락을 분석하여 보안 강도를 스스로 결정하고, 그에 상응하는 상호인증 및 암호화를 협상 및 적용한다. 또한, 요구 보안 레벨을 만족하지 못 할 경우 응답에 패딩터를 줌으로써 신뢰할 수 있는 응답 및 사용 환경을 보장한다.

기존과 달리 상호 인증 방식은 토큰을 요구하지 않으므로 토큰 탈취 및 재사용 등의 공격을 방지할 수 있다. 이와 더불어 인증 관련 메타 정보 (세션 식별자, 시퀀스 번호 등)들을 통해 세션 하이재킹, 리플레이 공격 등을 방지할 수 있고, 역할 기반 접근 제어를 함께 제공함으로써 과다 권한을 통제한다.

해당 접근은 LLM (로컬 및 API)과 양자 내성 암호 라이브러리를 활용한 실제 시나리오에서 높은 보안성을 제공하면서 암호화 및 전송 오버헤드가 무시 가능한 수준임을 보였다.

IV. 결론

본 논문에서는 AI 에이전트와 MCP에 대한 보안 위협과 이에 대한 대응책들을 살펴본다. MCP의 취약점에 대해 입·출력 감사, 양자내성 암호 적용, 프레임워크 전반의 보안 기술 적용과 같은 연구가 수행되고 있으며, 이는 프로토콜 수준에서 보안 규칙이 강제되지 않는 구조적 공백을 보완한다. 이러한 연구들을 기반으로 실제 AI 에이전트 환경에서의 보안성 보장을 위해서는 MCP에 대한 표준 프로토콜과 운영 및 구현 레벨에서의 요구 사항 등이 제도화되어야 할 필요가 있다.

V. Acknowledgment

This work was supported by Institute for Information & communications Technology Promotion(IITP) grant funded by the Korea government(MSIT) (No.2018-0-00264, Research on Blockchain Security Technology for IoT Services, 20%) and this work was supported by Institute of Information & communications Technology Planning & Evaluation (IITP) grant funded by the Korea government(MSIT) (No.RS-2025-02306395, Development and Demonstration of PQC-Based Joint Certificate PKI Technology, 40%) and this work was supported by the Institute of Information & Communications Technology Planning & Evaluation(IITP) grant funded by the Korea government(MSIT) (No. RS-2025-25394739, Development of Security Enhancement Technology for Industrial Control Systems Based on S/HBOM Supply Chain Protection, 40%).

[참고문헌]

- [1] IBM, "What are AI agents?," IBM Think, IBM Corporation, 2025. [Online]. Available:

- <https://www.ibm.com/think/topics/ai-agents> . [Accessed: Oct. 18, 2025].
- [2] Model Context Protocol Working Group, "Model Context Protocol – Server: Tools (Specification 2025-06-18)," modelcontextprotocol.io, Jun. 18, 2025. [Online]. Available: <https://modelcontextprotocol.io/specification/2025-06-18/server/tools> . [Accessed: Oct. 18, 2025].
- [3] Model Context Protocol Working Group, "Security Best Practices," Model Context Protocol (Draft Specification), [Online]. Available : https://modelcontextprotocol.io/specification/draft/basic/security_best_practices . [Accessed: Oct. 18, 2025]
- [4] Narajala, Vineeth Sai, and Idan Habler. "Enterprise-grade security for the model context protocol (mcp): Frameworks and mitigation strategies." *arXiv preprint arXiv:2504.08623* (2025).
- [5] SHOSTACK, Adam. *Threat modeling: Designing for security*. John wiley & sons, 2014.
- [6] FORCE, Joint Task. *Assessing security and privacy controls in information systems and organizations*. NIST Special Publication, 2022, 800: 53A.
- [7] Stafford, V. "Zero trust architecture." *NIST special publication 800.207* (2020): 800-207.
- [8] Kholkar, Gauri, and Ratinder Ahuja. "The AI Agent Code of Conduct: Automated Guardrail Policy-as-Prompt Synthesis." *arXiv preprint arXiv:2509.23994* (2025).
- [9] Yoon, Seyoung, Hyunji Kim, and Hwajeong Seo. "CA-MCPQ: A Context-Aware Post-Quantum Protocol for AI Agent Integrity and Security." *Cryptology ePrint Archive* (2025).